

Détection d'anomalies comportementales sur les sessions à privilèges

Une même session privilégiée traverse toute la chaîne, puis **deux modèles** l'analysent. L'objectif : montrer que les **règles ne suffisent pas**, et que le Machine Learning détecte ce qu'elles ne voient pas.

1 · LA CHAÎNE DE DONNÉES



WALLIX Bastion (PAM)

Enregistre chaque frappe clavier `KBD_INPUT` et l'envoie en syslog.



Wazuh (SIEM/XDR)

Décodeur + règles `100500-100599` → **archives** (chaque commande).



feature_extraction/

`extract.py` → sessions · `transform.py` → features



Modèles ML

Non supervisé (comportement) + supervisé (type d'attaque)

Principe d'intégrité : les données **GÉNÉRÉES entraînent** · les sessions **RÉELLES jugent** · on ne mélange jamais les deux.

admin

bastionsvc

Administration système générale.

non-sudo

dev

p_dev

Développeur — git, python, build.

sudo X NOPASSWD

dba

p_dba

Administrateur base de données.

sudo X NOPASSWD

auditor

p_audit

Auditeur — lecture, journaux.

sudo X NOPASSWD

attaques

p_admin

Étapes root (2^e mot de passe lab).

root

Signal d'insider fort — l'anomalie n'est pas seulement une IP inconnue, mais une **IP connue associée à la MAUVAISE identité** (l'IP habituelle de p_dev utilisée pour une session p_dba). Un sudo refusé sur un compte non-NOPASSWD = un vrai « privesc refusé » (fail_ratio).

NON SUPERVISÉ • PRIMAIRE

Comportement

« est-ce anormal ? »

ENTRAÎNÉ SUR **Bénin uniquement** — apprend le normal, ne voit aucun label d'attaque

MODÈLES ECOD · COPOD · Isolation Forest · HBOS (PyOD)

SORTIE Score d'anomalie → file classée
session → 0.94

MÉTRIQUE precision@k

Détecte l'**inconnu** — y compris le Pool B (aveugle aux règles). Porte la thèse.

SUPERVISÉ • SECONDAIRE

Type d'attaque

« attaque connue ? quel type ? »

ENTRAÎNÉ SUR **Généré bénin + attaque** 85:15 — nécessite des labels

MODÈLES Random Forest · LogReg (+ SMOTE)

SORTIE Attaque ? + tactiques cred_access
0.8

MÉTRIQUE precision@k · rappel/tactique

Précis sur le **connu** — mais aveugle, comme les règles, à ce qu'il n'a jamais vu.

Piège évité : les drapeaux de mots-clés (flag_*) réimplémentent les règles. On entraîne **Config A** (comportementale, SANS drapeaux — la thèse) et **Config B** (+ drapeaux — déploiement). Une seule matrice de features, chaque approche est un filtre.

4 • POOL A / POOL B – LA DÉMONSTRATION

ATTAQUE CONTENUE DANS LA SESSION	RÈGLES	SUPERVISÉ	NON SUPERVISÉ
Technique connue, mot-clé de règle cat /etc/shadow	■ déclenche	■ déclenche	■ déclenche
Même intention, autre outil Pool B • base64 /etc/passwd	● silence	■ peut déclencher	■ déclenche
Nouveau + vocabulaire jamais vu aveugle aux règles & hors entraînement	● silence	● silence	■ déclenche
Insider lent & cohérent 1 commande, heure & IP normales	● silence	● silence	● silence

Ligne surlignée = la contribution • dernière ligne = la limite honnête (aucune couche n'est un sur-ensemble de l'autre)

5 • MÉTRIQUES D'ÉVALUATION

precision@k

Métrique principale

k = budget d'alertes du SOC. PAS le ROC-AUC (trompeur en fort déséquilibre).

McNemar

Test apparié

ML seul vs règles seules sur les cellules discordantes → une p-value, pas une impression.

Rappel / tactique

Couverture

Quelles tactiques les règles couvrent vs le ML.

Risque ≠ anomalie

Pondération

Risque = score d'anomalie × poids d'impact (criticité de l'actif, fournie par la Sécurité).